FINGERPRINT // F773DAE6FE4D8C52

// CONFIDENTIAL STRATEGY //

OMNIPOTENCE ENGAGEMENT ARCHITECTURE

Strategic Nexus

Strategic Security Scoping v33.0 Omni-Review

ENTITY

Nexus Global Treasury

NEXUS SCORE

100%

100

NEXUS INDEX

1.1 Engagement Coverage Index

This score reflects the breadth of technical validation across core governance pillars.

PILLAR	STATUS	PRIORITY
INTEL	VALIDATED	Strategic
COVERT	VALIDATED	Strategic
COLLAB	VALIDATED	Strategic
CRISIS	VALIDATED	Strategic

Business Profile & Objectives

PART I.A: BUSINESS CONTEXT

ENGAGEMENT PARAMETER	CLIENT SPECIFICATION
Engagement Description	**DORA-compliant Threat-Led Penetration Testing (TLPT) of core banking systems.**
Primary Deliverable	**Formal TLPT Red Team Execution Log and Remediation Plan.**

Resourcing & Schedule Summary

Executive Resourcing & Schedule Summary

The following summarizes the operational timeline and resourcing required to execute the defined Threat-Led Penetration Testing modules in alignment with regulatory mandates.

TOTAL ENGAGEMENT DAYS

4

ENGAGEMENT COMPLEXITY

HIGH

Automated TLPT Resourcing Allocation

ROLE	HEADCOUNT	PRIMARY RESPONSIBILITY
Threat Intel & Red Team Lead	1	Strategic oversight, regulatory coordination, and final QA.
Covert Red Team Operator	0	Technical execution, exploit dev, and assumed breach operations.

1.5 Regulatory Alignment: DORA Bank Resilience

Narrative: DORA resilience and TLPT-ready scoping for critical ICT systems, functions, and third-party ICT dependencies.

REGULATORY BODY — **Digital Operational Resilience Act (DORA) (European Union)**

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
Article 24	General Control Testing	ICT resilience testing programme.	Critical ICT systems.
Article 26	TLPT	Threat-led penetration testing.	Every 3 years for critical entities.

Mandatory Evidence Artifacts:

Asset Register | Threat Scenarios | TI Plan | Remediation Plan

IMPLEMENTATION GUIDANCE — **DORA**

ICT Asset Criticality Mapping

Under DORA, scoping must start with the ICT Asset Register. Every asset in scope must be mapped to a 'Critical or Important Function' (CIF). If an asset supports a CIF, it is subject to more rigorous testing and reporting requirements.

Third-Party ICT Risk

DORA requires that testing includes third-party ICT service providers where they support critical or important functions. This scoping pack must include a list of involved third parties and confirmation of their authorization to test.

Threat Intelligence Requirements

For TLPT (Threat-Led Penetration Testing), the scope must be driven by current, relevant threat intelligence. The scenarios defined in this pack should match the TTPs of actors targeting the financial sector.

IMPLEMENTATION GUIDANCE

MITRE

T1190 - Exploit Public-Facing Application

Adversaries may attempt to take advantage of a weakness in an Internet-facing computer or program using software, data, or commands in order to cause unintended or unanticipated behavior.

T1078 - Valid Accounts

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.

T1566 - Phishing

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering.

T1059 - Command and Scripting Interpreter

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries.

IMPLEMENTATION GUIDANCE

OWASP

A01:2021-Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification, or destruction of all data.

A02:2021-Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. This includes passwords, credit card numbers, health records, personal information, and business secrets.

A03:2021-Injection

Testing must validate that user-supplied data is not interpreted as commands or queries (e.g., SQL, NoSQL, OS command, ORM, LDAP, and EL expression or OGNL injection).

A04:2021-Insecure Design

Testing must evaluate the architectural design for missing or ineffective control design. Insecure design cannot be fixed by a perfect implementation.

Control 1: Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments.

Control 4: Secure Configuration of Enterprise Assets and Software

Establish and maintain the secure configuration of enterprise assets and software.

Control 12: Network Infrastructure Management

Establish, implement, and actively manage network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

Threat Scenarios & Modeling

PART I.C: THREAT INTELLIGENCE

Threat Intelligence Profiles

The following threat actors and attack scenarios have been selected to drive the execution methodology.

THREAT ACTOR	MOTIVATION	TARGET OBJECTIVE	PRIMARY TTPS
APT29 (Cozy Bear)	Espionage and data theft	Exfiltrate customer PII from the core banking database	Spearphishing, Living off the Land, Custom Malware
FIN7	Financial Gain	Compromise SWIFT payment gateways	Supply chain compromise, Ransomware deployment

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Payload & Exploit Transmission	Zero-Knowledge End-to-End Encryption (E2EE)
Exfiltrated Data Storage	Ephemeral Air-Gapped Analysis Environment (256-bit AES)
Red Team Telemetry Retention	Secure SOC Aggregation (Strict 30-Day Limit)
Artifact Destruction	NIST 800-88 Compliant Cryptographic Wipe

2.2 Data Sovereignty & Residency

To adhere to regulatory data protection requirements, the following residency rules apply to all engagement artifacts.

FRAMEWORK	RESIDENCY MANDATE
DORA	Must remain strictly within EU boundaries or approved adequate jurisdictions. Cloud storage requires EU-based tenants.

2.3 Regulator Audit & Access Rights

The following audit rights and access privileges are contractually granted to the respective regulatory bodies.

REGULATOR	ACCESS RIGHTS
DORA	European Supervisory Authorities (ESAs) must have full and unrestricted access to threat-led penetration testing results.

Operational Team Governance

White Team & Control Group Structure

In accordance with intelligence-led frameworks (CBEST/iCAST), the engagement must be overseen by a strictly segregated Control Group to ensure operational safety without alerting the defensive Blue Team.

GOVERNANCE BODY	REGULATORY RESPONSIBILITY	CLEARANCE LEVEL
The White Team	Engagement sponsors holding the emergency Kill-Switch. Responsible for defining the Critical Business Services (CBS) and Impact Tolerances.	Full Knowledge
The Control Group	A trusted subset of the client's internal IT/Security team who monitor the engagement for safety but do not participate in defense.	Full Knowledge
The Blue Team	The operational SOC and incident responders who must defend the network as if under a real attack.	Zero Knowledge
Threat Intel Provider	Independent vendor supplying the threat landscape profiles and attack scenarios to the Red Team.	Execution Phase
Covert Red Team	The execution unit simulating the Threat Actor's TTPs against the CBS.	Execution Phase

Critical Business Services & Impact Tolerance

PART II.C: CBS IMPACT TOLERANCE

Critical Business Services (CBS) Scope

ACTION REQUIRED: No Critical Business Services (CBS) have been declared. To satisfy financial TLPT mandates, the client must explicitly map the target infrastructure to its underlying business function (e.g., SWIFT Gateway) and define the maximum impact tolerance before testing begins.

Access & Test Data Readiness

Required access and data prerequisites.

PREREQUISITE	DESCRIPTION / STATUS
VPN Access	Client to provide OpenVPN profiles for two consultants.

Third Party ICT Supply Chain Scope

Third-Party ICT Dependency Register

The following third-party service providers (Cloud, SaaS, MSPs) host or manage in-scope assets and require explicit authorization.

PROVIDER	SERVICE TYPE	ASSETS HOSTED	AUTHORIZATION STATUS
AWS	Cloud Infrastructure	EKS Clusters, RDS Databases	Authorized (AWS Acceptable Use)
Okta	Identity Provider	Corporate SSO	Pending Notification

Technical Scope of Work

TI-PHASE — **Targeted Threat Intelligence Gathering**

Formally scoped intelligence gathering phase designed to identify threat actors, define attack scenarios, and produce the Threat Intelligence Profile required before Red Team execution.

Allocated Schedule: 1 Days

RT-COVERT — **Covert Red Team Execution**

Intelligence-led, objective-based penetration testing executing the scenarios defined in the TI-PHASE. Includes stealth, evasion, and assumed-breach scenarios against core financial systems.

Allocated Schedule: 1 Days

PT-REPLAY — **Purple Team Replay Exercises**

Collaborative replay of Red Team attack chains alongside the defensive Blue Team to validate SOC detections, incident response capabilities, and SIEM rule effectiveness.

Allocated Schedule: 1 Days

IR-VALIDATION — **Incident Response & Crisis Validation**

Executive tabletop and crisis management simulation based on the findings from the Red Team execution to validate Board-level incident response maturity.

Allocated Schedule: 1 Days

Execution Timeline (Gantt)

Omni Control Matrix

PART III.B: OMNI MATRIX

3.1 Omni Control Mapping

The following granular controls are in scope for the selected execution modules.

CONTROL ID	CONTROL NAME	FRAMEWORK	REFERENCE	IMPACT
CB_01	Core Banking Network Segmentation	DORA	Art 24	Critical
SW_02	SWIFT Gateway Isolation	CBEST	Objective A	Critical
IAM_03	Privileged Access Monitoring (PAM)	FRB	SR 13-1	High
TI_04	Threat-Led Defense Posture	iCAST	CFI-2	High
IR_05	Active Incident Response Capabilities	DORA	Art 26	Medium

RACI Governance

PART III.C: RACI MATRIX

3.2 RACI Governance Matrix

Responsibility Assignment Matrix for engagement activities.

ACTIVITY	THREAT INTEL PROVIDER	RED TEAM LEAD	CLIENT SECURITY OPS	CLIENT EXEC SPONSOR
Targeted Threat Intelligence Gathering	**I**	**R**	**C**	**A**
Regulator & Scope Notification	**I**	**C**	**A**	**R**
Covert Red Team Execution	**R**	**C**	**I**	**I**
Purple Team Replay Exercises	**R**	**I**	**C**	**A**
Regulator Artifact Submission	**C**	**I**	**R**	**A**

Regulatory Deliverables Schedule

Regulatory Deliverables Schedule

The following reports and evidence logs are contractually required to satisfy the loaded regulatory frameworks.

REGULATORY BODY	MANDATORY DELIVERABLE ARTIFACT
Digital Operational Resilience Act (DORA)	Asset Register
Digital Operational Resilience Act (DORA)	Threat Scenarios
Digital Operational Resilience Act (DORA)	TI Plan
Digital Operational Resilience Act (DORA)	Remediation Plan

Quality Assurance & Peer Review

PART IV.B: QUALITY ASSURANCE

Formal Quality Assurance Gate

Based on the selected regulatory frameworks and execution modules, the following QA routing is algorithmically enforced.

REQUIRED QA LEVEL: TLPT Qualified Red Team Reviewer

Mandatory Threat-Led Penetration Testing (TLPT) review gate. Evidence and kill-chain paths must be validated by a certified Red Team peer reviewer before report release.

Verification & Sign-off

PART V: AUTHORIZATION

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

FINGERPRINT // F773DAE6FE4D8C5277F00BA09A7EF2EB64A548549F267E31DA38F485DCCAA8EE

Engagement Sign-Off

By signing below, the client agrees that this unified scoping document satisfies the engagement coverage requirements for DORA, FRB, HKMA, and PRA compliance regimes.

Executive Sponsor: _____

Date: _____